

Руководство по выживанию — Kerberos

 pro-ldap.ru/tr/zytrax/tech/kerberos.html

Это руководство по выживанию посвящено системе Kerberos, в частности, Kerberos V (или Kerberos 5, кому как нравится), разработанной М.И.Т.. Предыдущая версия, — Kerberos IV (Kerberos 4), — имеет значительные отличия и в этом руководстве не рассматривается.

Содержание:

1. [Обзор Kerberos](#)
2. [Терминология Kerberos](#)
3. [Kerberos — последовательность входа в систему/аутентификации](#)
4. [Kerberos — доступ к сервису приложения](#)
5. [RFC по Kerberos](#)

Обзор

Kerberos 5 (в дальнейшем в этом тексте называемый просто **Kerberos**) — это сетевая система аутентификации, определённая в [RFC 4120](#) (с дополнениями в [RFC 4537](#) и [RFC 5021](#), оба добавляют возможности проведения переговоров, но не меняют основу протокола).

Кроме того, в [RFC 4121](#) определён метод, называемый GSSAPI (General Security System Application Program Interface, общий программный интерфейс систем безопасности), с помощью которого Kerberos-совместимые приложения могут напрямую вызвать службу Kerberos. Позднее GSSAPI был трансформирован для поддержки других (не Kerberos) систем обеспечения безопасности.

Kerberos может также использоваться для транспортировки информации по **авторизации**, но эта возможность рассматривается как специфичная для приложений и не определяется в RFC. Тем не менее, для транспортировки этой информации выделены общие поля ([раздел 5.2.6 RFC 4120](#)).

Kerberos широко используется повсюду в мире локальных и глобальных сетей и, возможно, в первую очередь в Microsoft, начиная с Windows 2000. В Kerberos активно используется [симметричное шифрование](#). Голова уже начинает болеть...

И для особо любопытных: название Kerberos является искажением имени Cerberus (Цербер), которое в Древнегреческой мифологии носил трёхголовый пёс, охранявший врата царства мёртвых, чтобы не дать людям улизнуть оттуда.

Обзор Kerberos

Kerberos предоставляет как сетевую **аутентификацию**, так и безопасный метод, посредством которого может быть проведена **авторизация** без необходимости повторного ввода пароля или предоставления других **удостоверяющих данных**. Поэтому он используется для обеспечения того, что обычно называется **Технологией единого входа (Single Sign-on, SSO)**. Для начала несколько общих определений:

Аутентификация (Authentication)	Процесс или процедуры, используемые для проверки того, что данные или информация, заявленные как поступившие из какого-то источника (от какого-то человека), могли поступить только из этого источника (от этого человека).
------------------------------------	---

Авторизация (Authorization)	После того, как пользователи прошли аутентификацию, они могут быть авторизованы на получение или запрет доступа к определённым системным/сетевым ресурсам, таким как файлы, приложения, либо возможность отправки электронной почты, выхода в Интернет и т.п. Процесс аутентификации обычно обеспечивает доступ к набору записей в базе данных по защите информации, которые содержат данные по доступу и/или дополнительные данные, основанные на принадлежности учётной записи к одной или нескольким группам. Термин "привилегия" иногда используется как синоним авторизации. Так, пользователь может иметь достаточно привилегий для доступа к ресурсу X, но не к ресурсу Y, или, иными словами, он авторизован на доступ к X, но не авторизован на доступ к Y.
--------------------------------	--

Удостоверяющие данные (Credentials)	Причудливое название того, что большинство из нас назвало бы паролем (хотя они могут принимать и иные формы, такие как аппаратный токен или биометрические данные). Ваши удостоверяющие данные являются одним из способов доказать, что Вы именно тот, за кого себя выдаёте. Так как Вы должны быть единственным человеком (или, в некоторых случаях, группой лиц) кто знает или имеет доступ к Вашим удостоверяющим данным, то когда Вы предоставляете их в системе или в сети и они совпадают с теми, которые ранее были безопасным способом занесены и сохранены в некоторую форму базы данных по защите информации, это доказывает, что Вы именно тот, за кого себя выдаёте. После выполнения неких форм обмена данными, которые будут включать в себя предоставление Ваших удостоверяющих данных (например, набор пароля), Вы становитесь аутентифицированы . Как правило, после аутентификации Вам ещё нужно быть авторизованным для доступа к ресурсам или информации.
--	---

Kerberos не делает никаких предположений о защищённости той сети, поверх которой он работает (по факту, он просто ей не доверяет). Однако, он предполагает, что хосты приложений и особенно хост, на котором работает Центр распределения ключей (Key Distribution Center, KDC) Kerberos, являются защищёнными.

Особенности Kerberos:

1. Пароли или иные удостоверяющие данные никогда не пересылаются по сети. Подразумевается, что сетевой трафик может быть прослушан, может произойти подмена сообщения или любая другая пакость.
2. Выдвигается обязательное требование, что информация о паролях/удостоверяющих данных хранится в единственном защищённом месте (Центре распределения ключей Kerberos). Поэтому удостоверяющие данные никогда не сохраняются на том хосте, который пользователь использует для входа/логина. После того, как произошёл первоначальный обмен в рамках **аутентификации**, этот хост должен забыть сведения о пароле.
3. Хосты/серверы приложений должны быть в состоянии подтвердить свою идентификационную сущность любому, кто запрашивает подобные доказательства.

4. Все коммуникации между аутентифицированными пользователями (клиентами) и сервисами приложений должны иметь возможность быть зашифрованными. С этой целью поддерживаются и могут применяться различные алгоритмы шифрования (все [симметричные](#)).

Терминология Kerberos

Как и у всех серьёзных систем, у Kerberos есть своя уникальная терминология, а кое-какие общие термины в контексте Kerberos обретают новый смысл. Постараемся раскрыть их простыми словами (во возможности):

Область действия (Realm)	Realm просто означает совокупность пользователей и серверов приложений, которые охватывает (или имеет о них информацию) Центр распределения ключей (KDC). Так, для того чтобы пользователь подсоединился (или вошёл) в Realm, у Сервера аутентификации (Authentication Server) этой области Realm должны быть сведения об удостоверяющих данных этого пользователя (и другая информация о нём), хранящиеся в защищённой базе данных безопасности того или иного вида (форма хранения не определяется в RFC). В терминологии Microsoft это будет называться Доменом (Domain) . Области Realm могут доверять другим Realm, в этом случае доверяющие друг другу области должны быть взаимно аутентифицированными (Cross-Authenticated) .
--------------------------	--

Форма имени Realm — **...@REALM** (регистр символов имеет значение). Например, если Realm называется **JOE**, то его **Realm-имя** будет **@JOE** (что отличается от Realm-имени **@joe**), а если Realm называется **EXAMPLE.COM**, то его Realm-имя будет **@EXAMPLE.COM**. (**Примечание:** Согласно текущей рекомендации ([раздел 6.1 RFC 4120](#)) в качестве имени REALM следует использовать доменное имя, которое часто преобразуется в верхний регистр.) Несмотря на то, что последняя форма может напоминать адрес электронной почты, никакого отношения к электронной почте она не имеет. Если буквы большие, это наверняка REALM, а не почта.

Принципал (Principal) **Принципал** — это строка, полностью идентифицирующая пользователя службы Kerberos. Он имеет форму **thing@REALM**. Принципал может быть именем сервиса, выполняющегося на хосте (мы будем называть его **принципалом сервиса (Service-Principal)**), или именем пользователя (мы будем называть его **принципалом пользователя (User-Principal)**). Принципалы формируют индексное поле для информации об объекте, хранящейся в базе данных безопасности Kerberos (в Центре распределения ключей или KDC). Форматы **принципалов** для пользователей и сервисов различаются.

Имя **принципала пользователя** — это приблизительный эквивалент **имени пользователя** или **имени учётной записи**. Оно имеет форму **principal-name[/instance-name]@REALM** (где часть */instance-name* является опциональной). Например, если имя пользователя в **принципале пользователя** — **alice**, а **Realm** — **joe**, то полный **принципал** будет **alice@joe**. Расширение instance-name позволяет любому пользователю иметь более одного принципала. Так, если **alice** является администратором области **Realm joe**, имя её принципала будет **alice/admin@joe**, и у этого принципала будут другие права (и удостоверяющие данные).

Если речь идёт о **принципале сервиса**, то форма имени принципала становится **service-name/QDN@REALM**, где QDN — это доменное имя хоста (без точки в конце, как того требует FQDN), на котором работает сервис, а **service-name** — это специфичная для приложения строка, идентифицирующая сервис на этом хосте. Некоторые типы сервисов используют ключевое слово **host**. Так, для сервиса **ftp**, работающего на хосте с именем **fileserver.example.com** в области **Realm @EXAMPLE.COM**, имя **принципала сервиса** будет **ftp/fileserver.example.com@EXAMPLE.COM**.

Разрешение (Ticket) — это структура данных, содержимое которой известно только издателю этого разрешения, и какой-либо стороне или сторонам, к которым это разрешение имеет отношение. Промежуточные хосты, такие как клиентский хост, рассматривают эти разрешения как **неразбираемый набор бит** и просто передают их на конечный пункт назначения. В Kerberos разрешения могут быть либо **Разрешениями на получение разрешения (Ticket Granting Tickets, TGT)**, — по сути представляют собой доказательства успешно пройденной аутентификации, — либо **Сервисными разрешениями (Service Tickets, ST)**, — выдаются Службой выдачи разрешений (Ticket Granting Service, TGS) и позволяют пользователю получить доступ к требуемому Сервису приложений (Application Service).

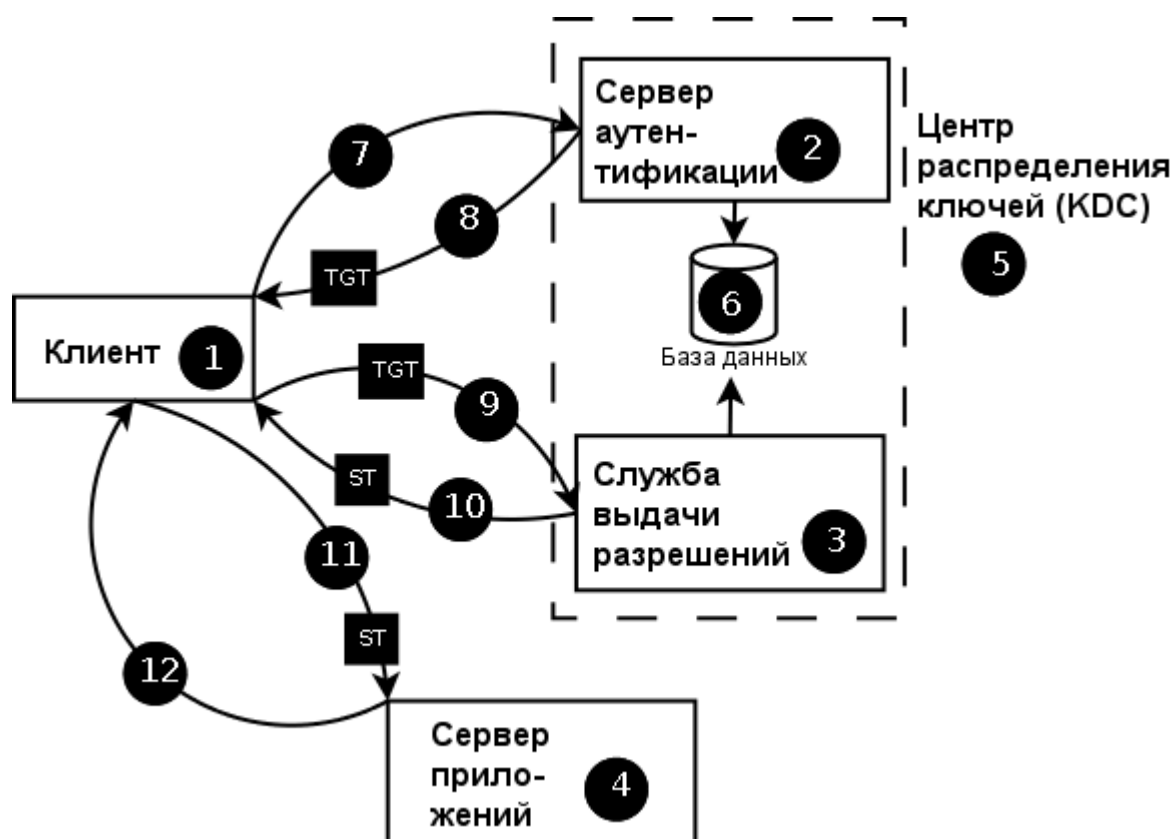


Рисунок 1: Обзор использования Kerberos

Двухминутный тур "Галопом по Kerberos":

1. Пользователь выполняет вход в систему на клиентском хосте (1), предоставляя при этом **принципал пользователя** и требуемый **принципал сервиса**, которые посылаются (7) Серверу аутентификации (Authentication Server, AS) (2) Центра распределения ключей (KDC) Kerberos (5).

2. Предположим, что **принципал сервиса** есть в базе данных безопасности (6). Сервер аутентификации (2) посылает (8) разрешение на получение разрешения (TGT), которое интерпретируется клиентом как **неразбираемый набор бит**, а также уникальный ключ сессии, зашифрованный удостоверяющими данными **принципала пользователя**.
3. При получении этого сообщения, клиент (1) запрашивает удостоверяющие данные пользователя, и, если он сможет расшифровать сообщение (8) с помощью представленных удостоверяющих данных, то эти удостоверяющие данные считаются корректными и пользователь становится **аутентифицированным**.
4. Когда **аутентифицированный** пользователь захочет получить доступ к сервису, клиент (1) посылает сообщение (9) Службе выдачи разрешений (Ticket Granting Service, TGS) (3) в составе KDC (5). В этом сообщении содержится TGT (полученный в сообщении (8)), а также имя требуемого **принципала сервиса**.
5. TGS (3) отправляет ответ (10) с сервисным разрешением (ST), разрешающим использование запрашиваемого сервиса. Это сервисное разрешение интерпретируется клиентом как **неразбираемый набор бит**.
6. Клиент (1) посылает (11) сервисное разрешение (ST) соответствующему Серверу приложений (Application Server) (4).
7. Сервер приложений (4) использует сервисное разрешение (ST) для проверки того, что запрашивающий авторизован на использование этого сервиса. Он отправляет ответ (12), только если клиент (1) запрашивал выполнение **взаимной аутентификации**, в противном случае с получением сообщения (11) процесс считается завершённым и можно начинать использовать сервис.

Kerberos кодирует все сообщения с помощью Abstract Syntax Notation - 1 (ASN.1) с использованием правил Distinguished Encoding Rules (DER), определённых в стандарте ITU X.690.

Kerberos — этап входа в систему

В этом разделе несколько более подробно (но не исчерпывающе) описываются различные диалоги протокола. В мельчайших подробностях форматы сообщений определяются в [RFC 4120](#), и для каждого типа сообщения мы приведём ссылку на соответствующий раздел этого документа. Цифры в скобках, встречающиеся в тексте, относятся к приведённому ниже рисунку 2:

1. Клиент (1) посылает сообщение KRB_AS_REQ (7) (оно же "Первоначальный запрос аутентификации" ("Initial Authentication Request")) Серверу аутентификации (AS) (2), который логически является составной частью KDC (5). Это сообщение посылается **открытым текстом** (без какого-либо шифрования). Оно содержит имя **принципала пользователя**, имя **принципала сервиса**, к которому пользователь хочет подключиться (как правило, принципала Службы выдачи разрешений (TGS), имеющего название **krbtgt/REALM@REALM**), опциональный список IP-адресов, которые пользователь хочет использовать, опциональное время жизни для этого входа в систему, а также метку nonce (случайное число), используемую как для идентификации ответов, так и для снижения риска подвергнуться атакам воспроизведения (replay attacks).
2. Сообщение KRB_AS_REQ определено в разделах [3.1.2](#) и [5.4.1 RFC 4120](#).
3. При получении этого сообщения AS (2) проверяет наличие **принципала пользователя** и **принципала сервиса** в базе данных безопасности (6) и выдаёт сообщение об ошибке, если они не найдены. **Примечание:** RFC по Kerberos оставляют формат базы данных безопасности на усмотрение разработчиков системы. В мире Windows это Active Directory (структура, основанная на [LDAP](#)).
4. Сервер аутентификации (2) отвечает одним сообщением KRB_AS_REP (8), которое состоит из:
 1. Случайным образом сгенерированного ключа сессии, времени жизни этого ключа, отметки времени timestamp и копии метки nonce, полученной от клиента (1). Эта информация шифруется с использованием удостоверяющих данных **принципала пользователя**.
 2. Разрешения на получение разрешения (TGT), зашифрованного с использованием ключа сервиса, запрашиваемого клиентом (обычно Службы выдачи разрешений). Это TGT, с точки зрения клиента, является неразбираемым набором бит, который просто передаётся TGS (3) при запросе доступа к конкретному Сервису приложений (4). Клиент не может интерпретировать содержимое TGT, поскольку у него нет (да ему и не надо) ключа, с помощью которого его можно было бы расшифровать.
 3. Сообщение KRB_AS_REP определено в разделах [3.1.3](#) и [5.4.2 RFC 4120](#).

5. При получении этого сообщения (8) клиент (1) может наконец запросить удостоверяющие данные пользователя и использовать их в качестве ключа для выполнения дешифрования полученного сообщения. Если удалось успешно расшифровать сообщение и исходная метка по-прежнему оказалась верной, то удостоверяющие данные пользователя должны быть корректными. После этого сведения об удостоверяющих данных пользователя могут быть сразу же забыты. Хотя системы, проводящие аутентификацию, могут запросить ввести удостоверяющие данные в тоже самое время, когда вводится имя учётной записи пользователя, на самом деле это не требуется, поскольку протокол Kerberos позволяет отложить запрос удостоверяющих данных вплоть до этого шага, чтобы минимизировать возможные негативные последствия при использовании небезопасной хост-системы или ПЭВМ.
6. Если предположить, что удостоверяющие данные были правильными, то пользователь с настоящего момента считается **аутентифицированным KDC**. У него также есть TGT (**неразбираемый набор бит**) и ключ сессии, так что теперь он может перейти к запросу сетевых сервисов с соответствующего Сервера приложений (4). Эти запросы описаны [далее](#).



Рисунок 2: Операции Kerberos

Примечание: Хотя сообщения на этом рисунке отмечены цветами так, будто они зашифрованы с использованием одного какого-либо ключа, это, конечно же, упрощение (более точную детализацию сообщений можно найти в их описании в RFC). Подсветка сообщений и связанная с ней легенда говорит о ключе, используемом получателем сообщения для расшифровки и проверки данных. Некоторые части каждого сообщения будут в открытом виде, для шифрования других

частей будут применяться иные ключи, которые всегда будут неизвестны получателю. Получатель интерпретирует такие части сообщения как **неразбираемый набор бит**.

Kerberos — запросы сервисов приложений

Цифры в скобках, встречающиеся в тексте, относятся к приведённому выше рисунку 2:

1. Если пользователь желает использовать сетевой сервис, он должен сначала получить Сервисное разрешение от TGS (3) KDC (5). Клиент (1) создаёт сообщение KRB_TGS_REQ (9) в Службу выдачи разрешений (TGS) (3) на получение Сервисного разрешения (ST) для целевого Сервиса приложений. Содержимое сообщения KRB_TGS_REQ:

1. **Принципал пользователя**, требуемый **принципал сервиса**, требуемое время жизни сервиса и разные другие поля. Эти данные не шифруются и используются TGS (3) для получения из базы данных безопасности (6) соответствующих ключей для других частей этого сообщения.
2. TGT (неразбираемый набор бит), которое было получено клиентом во время [последовательности обмена сообщениями этапа входа в систему](#). Оно уже зашифровано ключом, который неизвестен клиенту, но может быть получен TGS (3) из базы данных безопасности (6) с использованием **принципала пользователя**.
3. Структура **Authenticator**, которая состоит в основном из **принципала клиента (Client-Principal)**, метки поппсе (случайное число) и других данных. **Authenticator** шифруется с помощью ключа сессии, полученного во время [последовательности обмена сообщениями этапа входа в систему](#). Опционально, вместе с **Authenticator** клиент может предложить "подключ" (по существу, замену ключа сессии). При наличии этого подключа, TGS (3) должен использовать его для шифрования ответа.
4. Сообщение KRB_TGS_REQ определено в разделах [3.2.2](#) и [5.4.1 RFC 4120](#). Оно посылается (9) Службе выдачи разрешений (TGS) (3) KDC (5).

2. TGS (3) отвечает сообщением KRB_TGS_REP (10), которое состоит из:

1. Случайным образом сгенерированного ключа сессии сервиса приложений (который будет использоваться для шифрования последующих сообщений между клиентом (1) и Сервисом приложений (4)), времени жизни этого ключа, отметки времени timestamp, **принципала сервиса**, который был запрошен, и копии метки nonce (случайное число), отправленной клиентом (1). Эта информация зашифрована либо с использованием ключа сессии, полученного во время [последовательности обмена сообщениями этапа аутентификации](#), либо с использованием подключа (замены ключа сессии), предложенного клиентом в сообщении KRB_TGS_REQ.
2. Сервисного разрешения (ST), зашифрованного с использованием ключа Сервера приложений, на котором выполняется запрашиваемый клиентом сервис. Это разрешение содержит множество информации, интересной Сервису приложений. С точки зрения клиента, ST представляет собой неразбираемый набор бит, который передаётся Серверу приложений, когда тот требует подтвердить свои права. Клиент не может интерпретировать содержимое ST, поскольку у него нет (да ему и не нужно) каких-либо ключей, которыми он мог бы его расшифровать. Важная часть содержимого ST — копия ключа сессии сервиса приложений, сгенерированного TGS и также отправленного клиенту (смотрите пункт а). **Примечание: Серверы приложений** также проходят **аутентификацию** в KDC (5), используя процедуру, практически аналогичную [описанной выше](#) для аутентификации пользователя.
3. Сообщение KRB_TGS_REP определено в разделах [3.2.4](#) и [5.4.2 RFC 4120](#).
3. Клиент (1) расшифровывает свою часть структуры с помощью либо ключа сессии, либо предложенного им подключа, и извлекает и сравнивает метку nonce. Он также извлекает новый ключ сессии сервиса приложений.

4. Наконец, клиент (1) посылает Серверу приложений (4) сообщение KRB_AP_REQ (11) на запрос доступа. Это сообщение состоит из:
1. Структуры **Authenticator** пользователя, как определено выше для сообщения KRB_TGS_REQ. Эта структура **Authenticator** зашифрована с помощью ключа сессии сервиса приложений, полученного из предыдущего сообщения KRB_TGS_REP (10).
 2. Сервисного разрешения, полученного в предыдущем ответе (10).
 3. Клиент может запросить (с помощью флаг-поля в этом сообщении), что ему требуется провести **взаимную аутентификацию**. В этом случае Сервер приложений (4) ответит сообщением KRB_AP_REP, содержащим запрашиваемую информацию. Если взаимная аутентификация не запрашивается, то целевой сервис сразу же считается доступным, и в некоторых реализациях в этом же сообщении могут быть посланы данные, специфичные для целевого приложения.
 4. Сообщение KRB_AP_REQ определено в разделах [3.3.1](#) и [5.5.1 RFC 4120](#).
 5. Сервер приложений (4) отвечает (12) сообщением KRB_AP_REP только в случае, если была запрошена взаимная аутентификация. В противном случае считается, что целевой сервис доступен и ожидает поступления клиентских данных.
 6. Сообщение KRB_AP_REP определено в разделах [3.3.3](#) и [5.5.2 RFC 4120](#).

Примечания:

1. В разрешениях (как TGT, так и ST) могут опционально содержаться данные **авторизации** ([раздел 5.2.6 RFC 4520](#)). Конкретное содержимое этих полей специфично для разных типов приложений. Microsoft использует эти поля с данными **авторизации** для передачи **Атрибутных сертификатов привилегий** (Privilege Attribute Certificates, PAC).

RFC по теме

Неполный список связанных с Kerberos RFC.

RFC	Описание/статус
-----	-----------------

RFC 4120	The Kerberos Network Authentication Service (V5). Служба сетевой аутентификации Kerberos (версия 5). С. Neuman, Т. Yu, S. Hartman, К. Raeburn. Июль 2005 г. Отменяет RFC1510. Обновлён в RFC4537, RFC5021, RFC5896, RFC6111, RFC6112, RFC6113. Статус: PROPOSED STANDARD.
RFC 4121	The Kerberos Version 5 Generic Security Service Application Program Interface (GSS-API) Mechanism: Version 2. Механизм общего программного интерфейса систем безопасности (GSS-API) Kerberos версии 5: версия 2. L. Zhu, K. Jaganathan, S. Hartman. Июль 2005 г. Обновляет RFC1964. Обновлён в RFC6112. Статус: PROPOSED STANDARD.
RFC 6111	Additional Kerberos Naming Constraints. Дополнительные ограничения именования в Kerberos. L. Zhu. Апрель 2011 г. Обновляет RFC4120. Статус: PROPOSED STANDARD.
RFC 6112	Anonymity Support for Kerberos. Поддержка анонимности для Kerberos. L. Zhu, P. Leach, S. Hartman. Апрель 2011 г. Обновляет RFC4120, RFC4121, RFC4556. Статус: PROPOSED STANDARD.
RFC 6113	A Generalized Framework for Kerberos Pre-Authentication. Обобщенный механизм предварительной аутентификации для Kerberos. S. Hartman, L. Zhu. Апрель 2011 г. Обновляет RFC4120. Статус: PROPOSED STANDARD.
RFC 6251	Using Kerberos Version 5 over the Transport Layer Security (TLS) Protocol. Использование Kerberos версии 5 поверх протокола TLS. S. Josefsson. Май 2011 г. Статус: INFORMATIONAL.

Проблемы, комментарии, предположения, исправления (включая битые ссылки) или есть что добавить? Пожалуйста, выкроите время в потоке занятой жизни, чтобы [написать нам](#), [вебмастеру](#) или в [службу поддержки](#). Оставшийся день Вы проведёте с чувством удовлетворения.

Нашли ошибку в переводе? [Сообщите переводчикам!](#)

Copyright © 1994-2017 ZyTrax, Inc. Все права защищены. Последнее изменение страницы: 21 октября 2015 г. Переведено участниками проекта [Pro-LDAP.ru](#) в 2015-2017 г.